SCADA

목 차

1. SCADA의 정의 및 용도
2.SCADA의 주요 구성요소
3. SCADA System의 구조
4. SCADA System Interface
5. SCADA 관련 침해사례
6. Misconception about SCADA System Security
7. Security Vulnerabilities Affecting SCADA System
8. SCADA Security Strategy - Network Rings of Defense
9. SCADA System의 위협요소
10. SCADA Configuration & Technical Controls
11. SCADA System Attack Simulation 1/2/3
12. SCADA System 구축 시 고려사항
13. SCADA Technical Assessment Topics
14. SCADA Security Plan

SCADA의 정의 및 용도

1. 정의

Supervisory Control And Data Acquisition의 Initial로서, 원격지에 있는 설비를 운영자가 지정한 명령에 따라 설비를 제어할 수 있는 능력과 제어대상 기기가 지시한 대로 제어되고 있는 지의 상태를 감시하는 설비를 의미한다.

원방감시 제어는 운영자가 여러 곳에 분산 설치되어 있는 원격단말장치를 감시하고 필요에 의해 제어할 수 있도록 구축하는 시스템을 의미한다. SCADA 시스템은 원격지와의 통신을 통해 제어를 행하고 제어에 필요한 Data를 수집한다.

SCADA 시스템은 최첨단 고성능 하드웨어 기술, 고속의 데이터 통신 기술, 쉽고 편리한 운전기술을 집약한 산업설비의 종합관리 시스템으로 발전 및 전력 계통, 정수 및 하수처리, 플랜트 자동화 , 공정제어, 열병합 발전계통, 가스, 석유, 빌딩관리 등에 응용 가능한 종합 관제 시스템이다.

2. 용도

1.수자원 관리분야 – 상하수도 처리 감시제어시스템, 홍수경보 시스템, 수질감시 시스템
2.발전 설비 분야 – 송/배선 감시 시스템, 핵 발전소 감시 시스템
3.교통신호 관제 시스템
4.철도운행 상황 감시 시스템
5.대기오염 감시 시스템
6.Plant 감시 제어 시스템

SCADA의 주요 구성요소

1. Remote Terminal Units (RTU)

RTU는 현장에 설치된 각종 기기들의 정보를 취득하기 위하여 원격지에 설치된다.

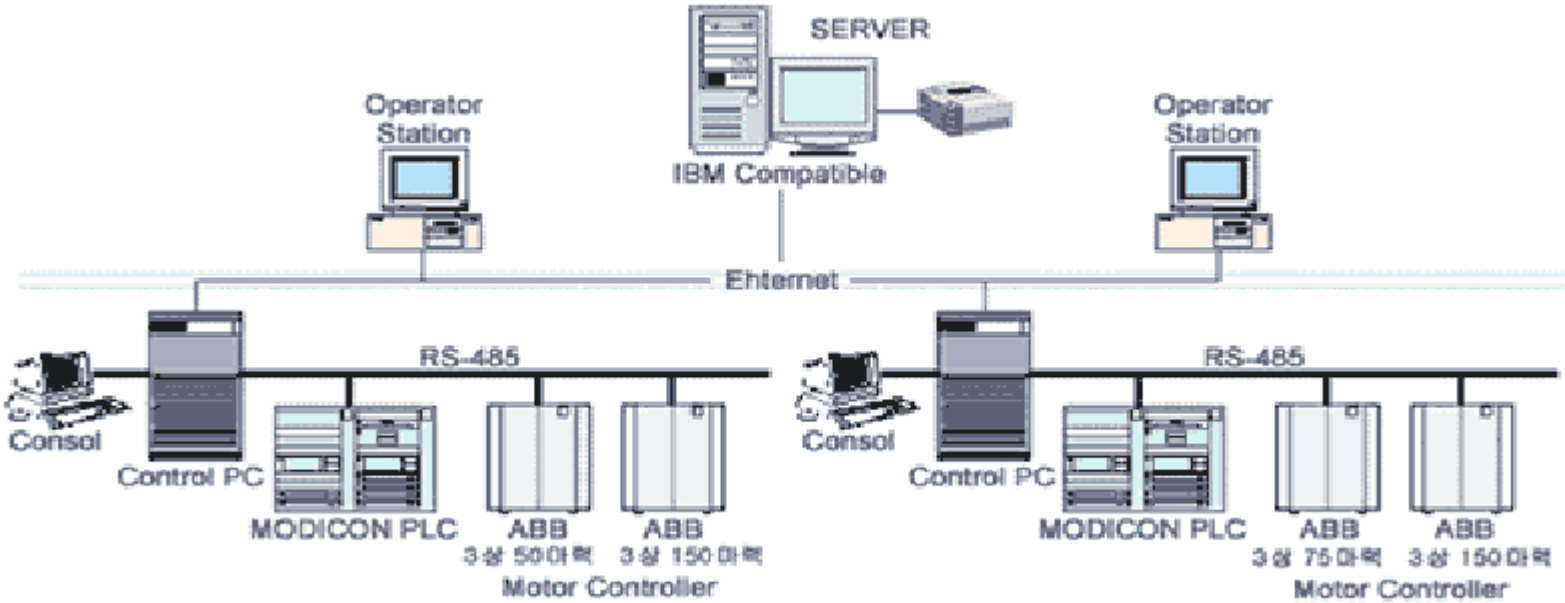
2. 통신장치

RTUs와 MTU 사이의 Data 전송을 위한 통신을 구현하는데 광통신(Fiber Optic), 공중전화망(Dial-up)등을 이용하여 구현될 수 있으나 일반적으로 전용선을 이용한 Modem을 통하여 이루어진다.

3. Master Terminal Units (MTU)

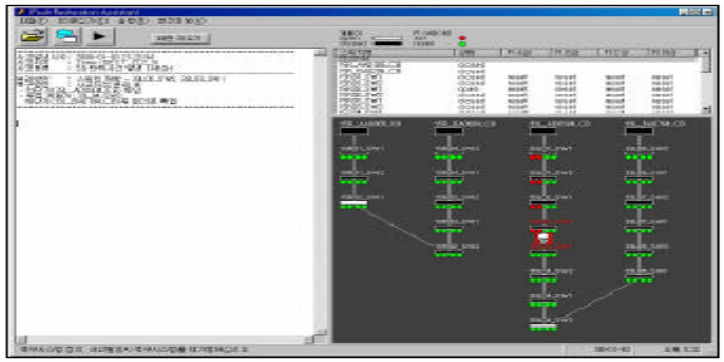
MTU는 제어실(Control Center)에 위치하며 운용요원에 의해 운영된다. 운영요원은 시스템 운영에 필요한 매개변수의 조절 또는 운영 중 발생된 문제를 해결하거나 시스템의 상태를 조작 또는 변경하기 위하여 시스템을 사용하며, 시스템의 제어는 일반적으로 KeyBoard나 Mouse등 MTU의 입력장비를 사용하여 이루어진다.

SCADA System의 구조(Ex. 발전설비)

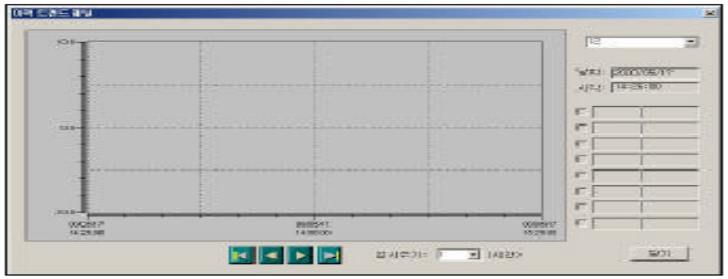


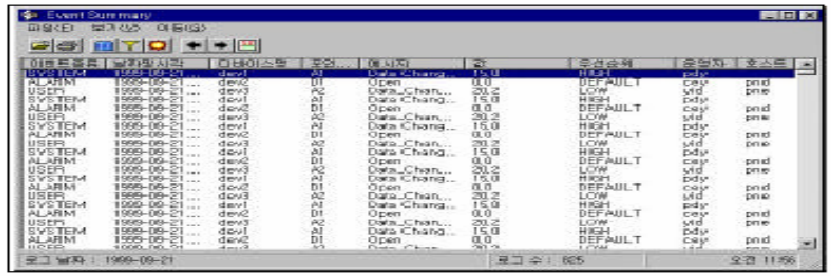
- MODICON(Modular Digital Controller), Computer, RS-485(주변장치 신호전송을 위한 장비), ABB(발전설비장비) 등으로 구성되어 있고, Ethernet 망을 바탕으로 구성되어 있으며, 제어 PC와 중앙 모니터링 시스템 등으로 구성됨
- PLC(Programmable Logic Controller)를 이용하여 Digital Signal을 전송하고 이를 통해 발전설비를 제어하는 형태로 구성되어 있고, Server와의 통신은 Control PC가 담당하며, Control PC에서는 명령을 PLC 형태로 변환하여 명령을 수행하는 형태로 되어 있음.

SCADA System Interface









- 각 System마다 Control 및 Log 기능이 존재하며 Visual한 형태로 Control System의 상태와 변화를 모니터링할 수 있음
- 현재 SCADA System의 변화 양상은 기존의 폐쇄된 환경의 System이 Ethernet 환경의 이용과 IT화된 제어시스템의 자동화를 통해 보다 효율적이고 능률적인 시스템으로 변화하고 있음

SCADA 관련 침해사례

1. 알카에다 조직원의 노트북 자료

아프카니스탄 전쟁 중 알카에다의 기지로 보이는 곳에서 알카에다 조직원의 소유로 보이는 노트북에서 Cyber terror에 이용될 수 있는 소프트웨어와 댐의 모형물이 발견되었다. 금속과 콘크리트 구조물을 분석하기 위한 Microstan 프로그램과 댐의 모형을 2D, 3D 형태로 구축하여 물의 흐름을 예상하기 위해 사용한 autocad 2000 프로그램이 발견되었다. 이 사건을 계기로 지난 9월 경에 발표된 중요기반 시설보호를 위한 보안책인 “The national strategy To SECURE CYBER SPACE” 를 발표하는 계기로 볼 수 있다.

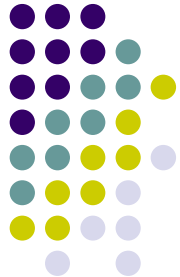
2. 1998년 루즈벨트 댐의 컴퓨터 시스템 해킹

1998년 12세의 해커는 애리조나의 루즈벨트 댐의 컴퓨터 시스템에 침입을 했고, 댐의 수문을 조종하는 SCADA System에 대한 완전한 제어명령을 알고 있었다고 연방기관은 발표했다. 루즈벨트 댐은 489조 갤런의 물을 담고 있으며 400 만 이상이 살고 있는 피닉스 시와 주변을 5피트 높이로 덮고 흐를 수 있는 양이다.

3. 2000년 4월 호주 퀸즈랜드의 SCADA System 침입 사건

2000년 4월 호주의 퀸즈랜드에서 훔친 컴퓨터, 무선전송기 및 자동차를 전송매개체로 사용하는 방법을 이용하여 폐기물 처리 회사의 자동화된 시스템을 제어하여 호수와 공원, 상업지역 외에 여로 곳을 오염시킨 혐의로 Vitek Boden 이라는 사람을 체포하였다. 2달 동안 40여 회 이상이 침입을 하여 폐기물을 싣고 가는 차량을 제어하여 폐기물을 쏟아 붓도록 만들었는데 시스템 관리자는 침입사실 조차도 몰랐다고 함.

Misconception about SCADA System Security



Misconception # 1

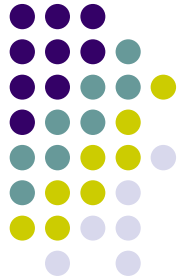
The SCADA system resides on a physically separate stand-alone network

Misconception # 2

Connections between SCADA systems and other corporate networks are protected by strong access controls

Misconception # 3

SCADA systems require specialized knowledge, making them difficult for network intruders to access and control



Security Vulnerabilities Affecting SCADA System

1. Common Vulnerabilities

- Web Site나 외부 공개된 System의 경우 침입자에게 회사구조 및 이름, 이메일 주소, 정보 시스템의 이름과 같은 다양한 정보를 제공하여 사회공학적인 해킹에 의한 침해 및 개인 정보를 이용한 해킹 및 바이러스 공격 가능성 존재
- DNS Server는 Zone-Transfer를 허용하는데 IP와 서버명, E-mail 정보를 제공하며 Transfer 가 가능한 구조로 이루어져 있어 획득한 정보 변경 가능

2. Network Structure

- FTP, WEB, Mail Server의 설정이 부적절하거나 불필요하게 내부 정보망에 대한 접근을 허용하는 경우
- 시스템 제작업체와의 Network 연결이 Firewall, IDS, VPN 등을 사용하지 않아 우회공격을 통한 침해 가능성 존재
- 서로 다른 Network Segment 사이에 분리가 되지 않아서 Firewall이나 Network 연결의 통제가 내부적으로 이루어지지 않을 경우의 취약점

3. Lack of Real-Time Monitoring

- 많은 Network 장비의 이용으로 인한 과다한 Log 발생으로 인한 중요 정보 확인의 어려움
- IDS가 존재하여도 보안관리자는 개별적인 공격만 인지함으로써 종합적인 공격을 인지하지 못하여 위험여부를 판별하지 못함

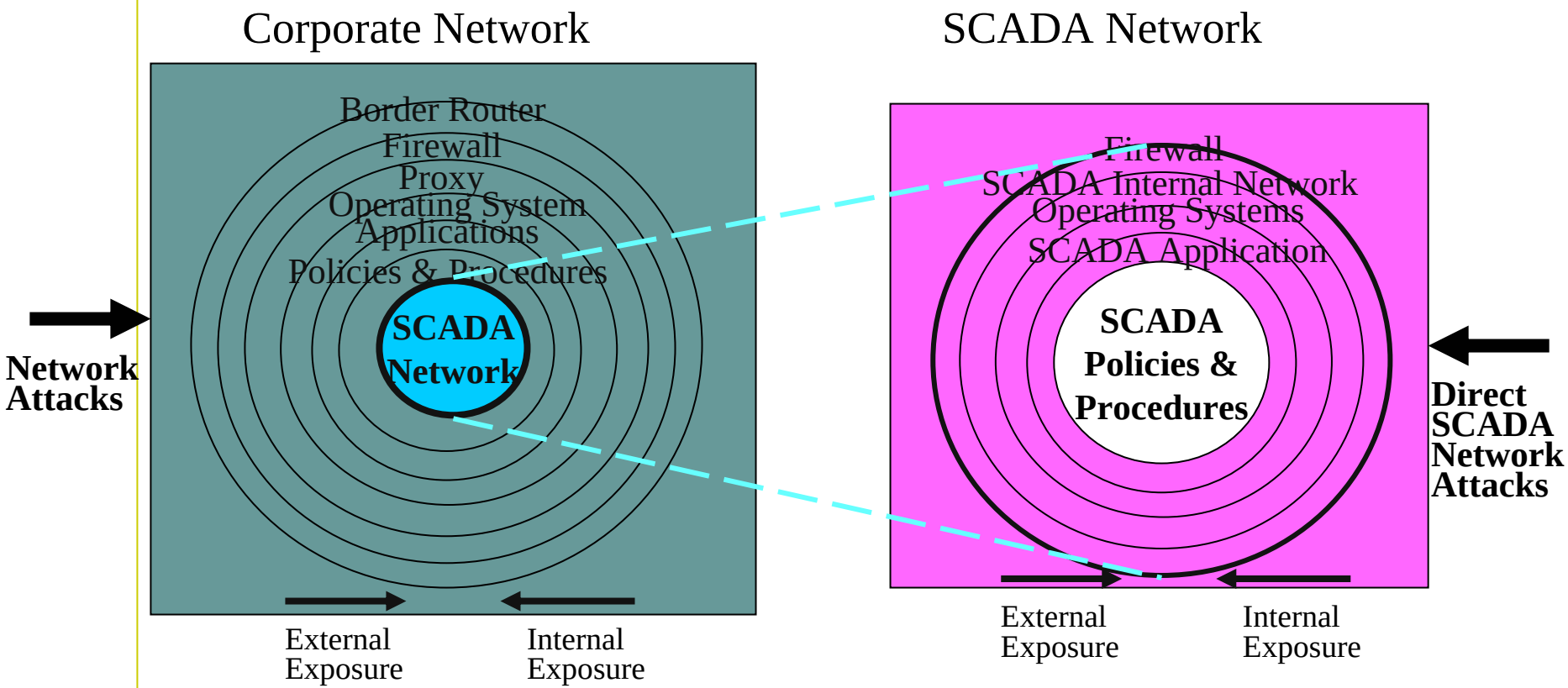
4. SCADA Control System의 변화 경향

- User Interface를 위해 VB, 델파이 등의 RAD Tool을 이용해 개발하는 경우가 많고 Data 연결을 위해 ODBC Interface를 이용하는 경우가 많음 ➔ 해커나 공격자가 쉽게 익힘
- Enterprise Information System에 일정부분 연결이 가능하도록 TCP/IP 망을 기본적으로 지원함 ➔ 일반화된 Protocol이므로 쉽게 접근 가능

SCADA Security Strategy - Network Rings of Defense

Attacks can originate from

1) either Internet Paths through the corporate network to the SCADA network.
2) within the SCADA network from either upstream(applications) or downstream(RTUs) paths.



SCADA System의 위협요소

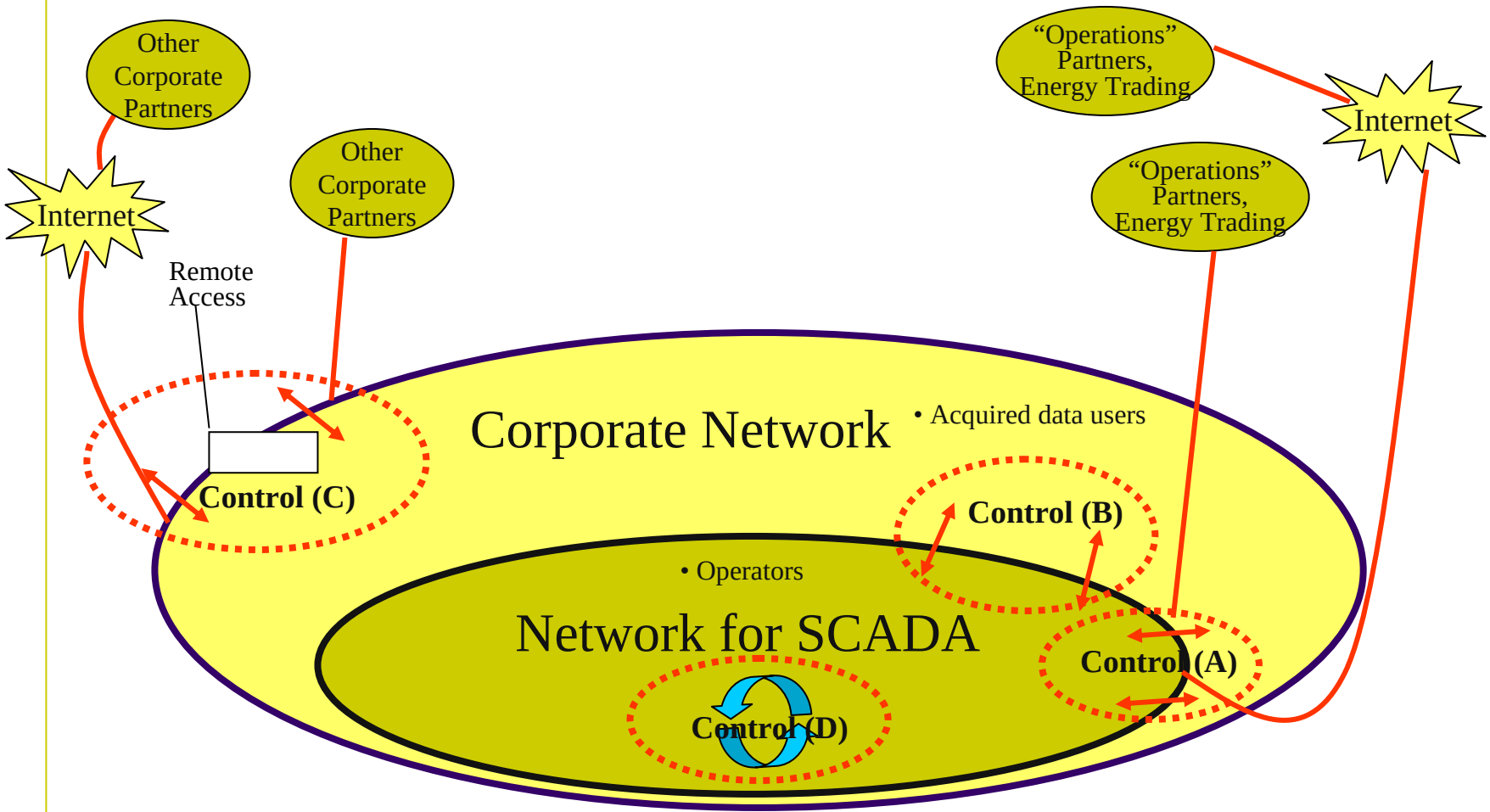
1. **Enterprise Information System과 Control System의 연결 시에 침해 사고 발생 가능성 존재**

2. **Control System에 대한 Utility와 Tool을 이용한 외부에서의 원격침해 가능성**

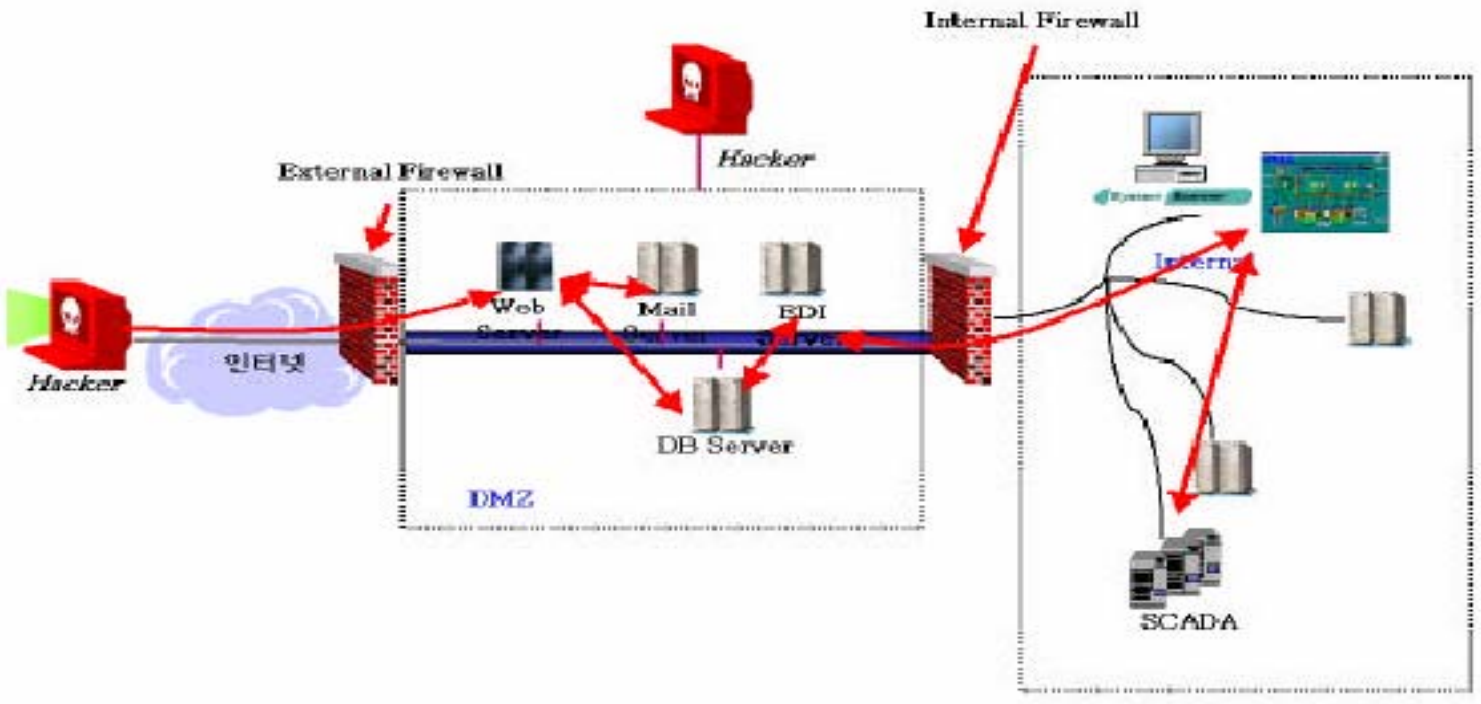
3. **Control System을 제작한 Vendor의 원격지원이나 접근을 위한 서비스나 Port의 연결로 인한 침해발생 가능성**

4. **내부자가 원격에서 Remote management tool을 이용하여 Control System을 Control하려고 할 때의 침해 발생 가능성**

SCADA Configuration & Technical Controls

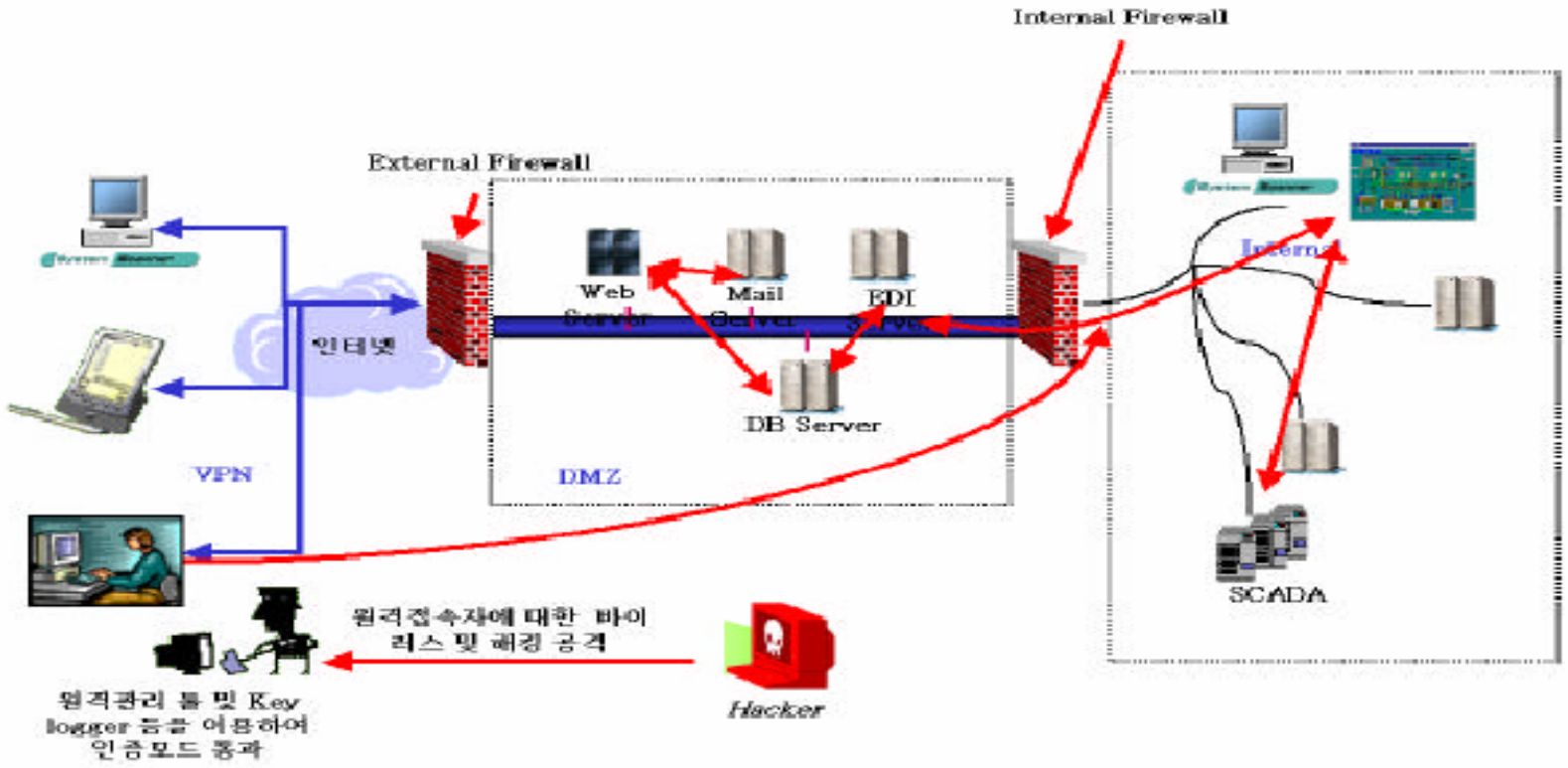


SCADA System Attack Simulation 1



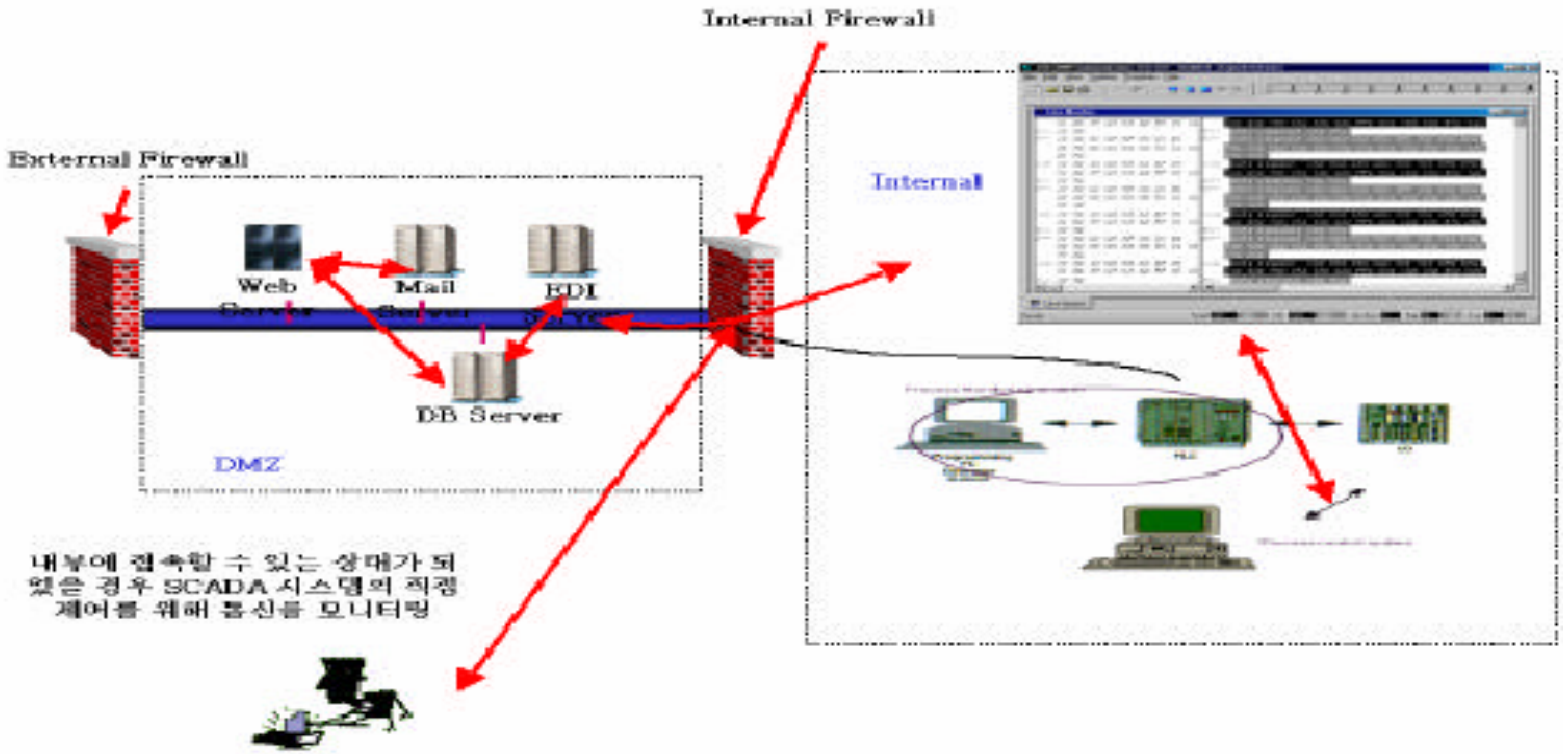
- 외부에 노출된 DMZ 영역내의 Web Server 와 Mail Server 등의 취약점을 이용하여 제어권 획득
- 사설 IP 대역대를 사용하는 Internal Network에 대한 정보를 수집하여 내부 Internal Firewall을 우회하거나 통과한 뒤에 SCADA System 공격

SCADA System Attack Simulation 2



- 원격에서 관리를 하거나 재택근무자가 Control 할 경우 공격 Scenario
- 원격 근무자나 재택근무자의 Server이나 PC를 Virus 와 해킹의 수단으로 직접 공격하여 백도어를 설치하여 Firewall의 인증모드를 피하여 ID와 Password 및 인증서 등을 확보한 후 직접 내부망에 대한 공격 시도

SCADA System Attack Simulation 3



- DMZ 구역을 통과한 후에 내부망에 직접 Access 할 수 있을 경우의 침입 경로
- SCADA System을 Control 하는 System에 접근하지 못할 경우 SCADA System과 통신이 이루어지는 PLC(Programmable Logic Controller) Line의 통신 Signal을 Packet Capture하여 Command Signal을 분석하여 직접 Control 가능(PLC Command는 짧고 간단하기 때문에 쉽게 분석 가능)

SCADA System 구축 시 고려사항

1. 현재까지의 Control System은 폐쇄 환경에 맞추어서 개발이 되어 있으므로 접근제어 및 인증에 대한 고려가 되어 있지 않다. 하지만 현재 구축환경은 폐쇄 환경으로 구축되는 경우는 예외적인 경우에만 구축이 되도록 빠르게 변화하고 있다.

2. RTU와 IED는 IP 통신을 지원하는 형태로 변경이 되어가고 단순한 기능에서 점점 더 많은 기능을 포함해서 복잡해져 가고 있다. 이에 따른 보안구조도 변경되어야 한다.

3. 새롭게 나오고 있는 Device Protocol (ex. UCA/MMS & DNP)은 보안기능을 지니며, 보안 속성을 지원하는지 여부를 확인

4. Legacy System과의 연결이 필요하므로 보안의 범위를 Legacy System과의 연동도 고려한 구축이 이루어져야 한다.

5. 실시간 정보 제공을 위해 예측 못한 요구사항이 생길 수 있으므로 기반구조 설계 시에는 실시간 정보의 제공을 위한 새로운 요구사항과 이에 따른 보안 사항으로 다루도록 고려

6. IDS는 Control Utility Protocol을 인식하지 못함을 알고 보안구조가 고려되어야 한다. 즉, TCP/IP망이 아닌 PLC Line을 이용하여 일치하는 Pattern을 찾을 수 없으며 탐지도 불가능한 형태이다.

SCADA Technical Assessment Topics

Control Points	Technical Assessment Topics
A	● Location & sensitivity of data ● Topology ● Network Access Controls ● System access controls ● User Authentication ● User Entitlements ● Auditing & logging ● Intrusion detection ● Physical controls
B	● The security of common points of management (e.g. SNMP, Consoles) ● Trust relationships at the Operating System(OS) level ● Protection of key shared resource infrastructure(e.g. Domain Name Services)
C	● Firewall topology & rule base ; other Internet controls like content filtering ● Authentication ● Auditing & logging ● Intrusion detection ● Wireless Local Area Networks ● Operating System hardening
D	● Server hardening ● Network equipment access controls ● Server access controls ● Physical security ● Console security ● Secure communications ● Authorization according to principles of least privilege & segregation of responsibility ● Wireless Local Area Networks

SCADA Security Plan

1. Security Policy

- Cyber Terror 및 Cyber war에 대비하여 국가 단위의 기반시설 보호기구 설립
- 미래 발생 가능한 바이러스 및 해킹에 대한 연구
- 기반시설에 대한 외부 접속 지점의 최소화 및 엄격한 관리와 보안정책 필요
- 기반시설의 외부 정보 제공 접점이나 연결지점의 엄격한 관리
- 기반시설 Control System을 원격에서 직접 Control System에 접근을 하지 못하도록 정책 설정
- 기반시설과 연결된 내부 사용 PC와 Server군에 대한 Virus 및 해킹 대책 완비
- 내부 사용자에 대한 보안교육 강화 및 보안 조직 강화
- 기반시설 시스템 제작 업체에서의 원격지원 최소화
- 기반시설 Control System에 대한 대외정보 유출 금지
- Solution 도입 시 보안방안에 대한 철저한 검토

2. Security Technic

- 외부 접속이 필요할 경우의 엄격한 제한 및 권한 제어 필요
- DMZ 내의 시스템에 대한 보안강화 뿐 아니라 내부망에 대한 자체 보안성을 높일 것
- VPN의 사용 뿐 아니라 Server 자체에 대한 무결성 도구를 이용하여 보안을 높일 것
- 내부망에 대한 접속 경로의 최소화와 모니터링 집중도를 높일 것
- E-mail의 암호화 및 File/Directory에 대한 Locking을 강화할 것
- 정기적이고 철저한 보안성 검사 및 취약성 점검을 수행할 것
- SCADA 장비의 비 정상적인 움직임이 나타나는 경우의 Control 방안 강구 및 모니터링 방안에 대한 고려